

CYROPAY LTD

Supplier Security Policy

Document Classification: Internal
Document ID: POL-006
Version: 1.0
Policy Owner: Chief Information Security Officer (CISO)
Approved By: Chief Executive Officer (CEO)
Effective Date: May 2026
Review Date: May 2027
Status: Approved

1. Purpose

This policy establishes CyroPay Ltd’s requirements for managing information security risks arising from relationships with third-party suppliers, service providers, and partners. It ensures that third parties handling CyroPay data or accessing CyroPay systems meet appropriate security standards proportionate to the risk they represent.

2. Scope

This policy applies to:

- All third-party suppliers, service providers, contractors, and partners with access to CyroPay systems, data, or premises.
- All cloud service providers, SaaS platforms, and critical infrastructure providers.
- Internal teams responsible for procuring, managing, and reviewing third-party relationships.
- CyroPay employees managing supplier contracts and relationships.

3. Definitions

Term	Definition
Third Party	Any external organisation or individual providing services to or on behalf of

	CyroPay
Critical Supplier	A supplier whose failure or compromise would materially impact CyroPay's operations or security
Supplier Risk Assessment	A structured evaluation of a supplier's information security controls and risk posture
Due Diligence	Pre-onboarding review of a supplier's security, financial, and legal standing
Fourth Party	A subcontractor or sub-processor used by a CyroPay supplier

4. Roles and Responsibilities

4.1 CISO

1. Owns this policy and maintains the supplier risk register.
2. Approves critical supplier onboarding and reviews.
3. Escalates unacceptable supplier risks to senior management.

4.2 Procurement and Legal

1. Ensure security requirements are included in all supplier contracts.
2. Obtain completed security questionnaires prior to contract signature.
3. Notify the CISO of new or material changes to supplier relationships.

4.3 Relationship Owners

1. Manage day-to-day supplier relationships.
 2. Monitor supplier performance and security compliance.
 3. Escalate supplier security issues to the CISO.
-

5. Policy Requirements

5.1 Pre-Onboarding Due Diligence

1. All new suppliers must complete a security risk assessment before being onboarded.
2. Suppliers processing personal data must undergo a Data Protection Impact Assessment (DPIA) review where required under UK GDPR.
3. Critical suppliers must provide evidence of relevant security certifications (e.g. ISO/IEC 27001, SOC 2 Type II PCI DSS).
4. The CISO must approve the onboarding of any supplier classified as high risk.

5.2 Contractual Requirements

1. All supplier contracts must include information security requirements appropriate to the risk level.
2. Contracts must include the right for CyroPay to audit supplier security controls.
3. Data processing agreements (DPAs) must be in place for all suppliers processing personal data.
4. Contracts must include incident notification requirements aligned to CyroPay's regulatory obligations.
5. Contracts must address data return and destruction obligations upon termination.

5.3 Ongoing Monitoring

1. Critical suppliers must be subject to annual security review.
2. All other suppliers must be reviewed at least every two years.
3. Supplier security certifications and compliance evidence must be tracked and refreshed.
4. Significant supplier incidents must be escalated to the CISO.
5. Fourth-party risks must be considered as part of critical supplier assessments.

5.4 Access Controls for Third Parties

1. Third-party access must follow the Access Control Policy (POL-003).
2. Third parties must use unique, individual accounts and must not share credentials.
3. Third-party access must be reviewed quarterly.
4. Access must be revoked immediately upon contract termination.

5.5 Cloud and SaaS Providers

1. Cloud providers must be assessed for data residency, encryption, incident notification, and exit provisions.
2. AWS as the primary cloud provider is subject to ongoing review including review of AWS compliance reports (SOC 2, ISO 27001).
3. Use of new SaaS tools must be approved through a formal security review process before adoption.

6. Exceptions

Exceptions must be approved by the CISO, documented with risk justification, and include a remediation timeline.

7. Related Documents

1. POL-001 Information Security Policy
 2. POL-003 Access Control Policy
 3. POL-005 Incident Response Policy
 4. POL-006 Data Classification and Handling Policy
-

8. ISO/IEC 27001:2022 Annex A Mapping

Annex A Control	Description
A.5.19	Information security in supplier relationships
A.5.20	Addressing information security within supplier agreements
A.5.21	Managing information security in the ICT supply chain
A.5.22	Monitoring, review and change management of supplier services
A.5.23	Information security for use of cloud services

9. Document Control

Version	Date	Author	Changes
---------	------	--------	---------

1.0	May 2026	CyroPay GRC Team	Initial version
-----	----------	---------------------	-----------------